OCCPL Innovations

Multi-Product SaaS Platform

Phase plan and project status report

Overall	Phases 1–5 complete. Awaiting approval to start Phase 6 (Plans, subscriptions & entitlements).
Progress	5 of 10 phases complete.
Tests passing	Backend: 31 unit/slice tests and 48 integration tests against real MySQL 9.7, Keycloak 26.8.1, Redis 8.10 and SMTP. Frontend: 14 tests, lint, format and production build.
Try it	Local Docker stack: API docs with Keycloak sign-in at http://localhost:8080/swagger-ui.html; every outgoing email (e.g. invitations) in the Mailpit inbox at http://localhost:8025. Admin screens arrive in Phase 8.
Not yet verified	GitHub CI has not run yet (first run on next push). Docker image build stages could not run in the development sandbox (no network inside docker build); runtime images were verified.
Next step	Phase 6 (Plans, subscriptions & entitlements) on approval. Decide the grace period and data retention (D-5) then.

Phase overview

#	Phase	Status	Scope
1	**Discovery & architecture**	Done	Architecture, data model, security model, API inventory, backlog, ADRs
2	**Foundation**	Done	Backend & frontend skeletons, Docker stack, CI, error handling, observability
3	**Identity & access**	Done	Keycloak login mapping, roles & permissions, company-level checks, MFA, rate limiting
4	**Company & membership management**	Done	Company lifecycle, invitations, member roles, audit trail
5	**Product catalogue**	Done	Product registration, versioned configuration, features
6	**Plans, subscriptions & entitlements**	Planned	Plans, prices, limits, subscription lifecycle, usage enforcement
7	**Provisioning & sample product**	Planned	Reliable provisioning with retries; reference product service
8	**Frontend portals**	Planned	Super Admin and Company Admin screens
–	**Billing (Razorpay)**	Planned	Gateway invoices, payment webhooks, idempotency
9	**Hardening**	Planned	Security review, isolation suite, load tests, backup drill
10	**Deployment**	Planned	Production setup, monitoring, runbooks, rollback

Decisions and technology

Topic	Decision
Versions	Latest stable; latest LTS where a choice exists (ADR-0007)
Login provider	Self-hosted Keycloak (identity data stays in OCCPL infrastructure); MFA required for OCCPL staff
Payments	Razorpay; invoices generated by Razorpay, Core stores references
Grace period / retention	Deferred — to be decided when subscriptions are built (Phase 6)
Architecture	Modular monolith for the Core Platform; products are independent services

Component	Version	Note
Java	25 LTS	Java 27 is newer but has ~6 months of support
Spring Boot	4.1.1	Spring Framework 7, Security 7, Hibernate 7.4, Jackson 3
Angular	22.2	TypeScript 6, Vitest, zoneless
MySQL	9.7 LTS	26.7 is a short-support innovation release
Keycloak	26.8.1	Self-hosted
Redis	8.10	Rate limiting (Phase 3), caching later
Nginx	1.30	Unprivileged container for the portal

Phase details

Phase 1 — Discovery & architecture

Done

Delivered / scope

- Project scope, assumptions, open decisions and risks (PROJECT.md)
- Module boundaries and dependency rules, integration contract for product services (ARCHITECTURE.md)
- About 35-table data model, subscription state machine, usage-limit rules, migration strategy (DATABASE.md)
- About 80 API endpoints with required permissions; standard error format (API_SPEC.md)
- Authentication, authorization and tenant-isolation design (SECURITY.md); 7 architecture decision records

Phase 2 — Foundation

Done

Delivered / scope

- Backend skeleton: standard JSON errors with tracking IDs, login-token validation, CORS allowlist, security headers
- Health checks and metrics on an internal port; structured JSON logs; database migrations
- Portal shell: runtime configuration, API error handling, design tokens (light/dark), lint and formatting
- Docker Compose stack (MySQL, Keycloak, backend, portal); GitHub Actions CI; weekly dependency updates

Verified

- 22 unit/slice tests and 5 integration tests (MySQL 9.7); 14 frontend tests; production build
- Full stack started locally: real Keycloak tokens accepted; wrong audience, issuer or tampered tokens rejected
- Portal loaded in a browser at phone width with no errors (a CSP issue was found and fixed)

Phase 3 — Identity & access

Done

Delivered / scope

- Database tables for users, identities, profiles, companies, memberships, roles, permissions and audit log
- Seeded catalogue: 28 permissions and 5 built-in roles (Super Admin, Platform Support, Company Admin, Manager, User)
- Sign-in mapping: users created or linked on first login only with a verified email; disabled accounts blocked; an email cannot be taken over by a second Keycloak account
- First Super Admin set by a one-time configured email; every change audit-logged
- Two-factor login for OCCPL staff: platform permissions withheld until the login used an authenticator app
- Platform role management API; the last Super Admin cannot be removed
- Company-level checks: another company's data returns 'not found'; suspended companies are read-only
- Endpoints: GET /api/v1/me, PUT /api/v1/me/profile, GET /api/v1/permissions
- Keycloak admin client (create users, required actions, enable/disable, logout)
- Rate limiting per user / per IP using Redis; requests still allowed if Redis is down (failure is counted)

Verified

- 6 application integration tests incl. migrations and seed data on MySQL 9.7

- 15 tenant-isolation tests: cross-company access, role limits, suspended/deactivated states, MFA rule, first-login rules, concurrent first login, last-Super-Admin rule, profile validation
- 3 Keycloak tests: admin client via service account; token audience/issuer checks; first Super Admin with authenticator-app enrolment and OTP login through Keycloak's real login pages
- 2 rate-limit tests with real Redis plus a fail-open test
- Docker stack: sign-in from Swagger UI through Keycloak in a real browser, GET /api/v1/me

Open item

- A dedicated expired-token test (expiry is enforced by the framework's default validator)

Phase 4 — Company & membership management

Done

Delivered / scope

- Companies: create with primary contact and initial Company Admin invitation in one step; search, edit (company admins may change only the display name), activate/suspend/deactivate with history
- Company settings incl. allowed email domains for invitations; contacts (primary, billing, technical)
- Invitations: invite, resend, revoke, accept, automatic expiry; links are one-time and stored only as hashes
- New users get a Keycloak 'set your password' email that returns to the accept link; existing users get the platform's invitation email
- Members: list/search, suspend/reactivate/deactivate, change roles — nobody can grant more than they have, change their own membership, or remove the last Company Admin
- Platform users: list, disable/enable (also in Keycloak), memberships across companies
- Audit log search for OCCPL staff and per company for company admins
- Email outbox with retries; local Mailpit inbox shows every email

Verified

- 13 company/membership tests incl. every negative rule; 3 email outbox tests (delivery, retry, rollback)
- 2 end-to-end invitation tests with real Keycloak and SMTP: new admin sets password via the emailed link and joins; existing user accepts the platform email
- Docker stack: company created over the API, invitation email visible in Mailpit

Open item

- Custom company roles; branded Keycloak email text; Idempotency-Key header; seat limits (Phase 6)

Phase 5 — Product catalogue

Done

Delivered / scope

- Register products (start as draft) with app URL, API URL and the identifier their service accepts in tokens
- Edit, activate (only after a configuration is published), retire and reinstate products; every change audited
- Versioned configuration: each version is checked against a published schema, can never be edited, and can be published or rolled back; configurations that contain secrets are refused
- Features per product: on/off features and limits (seats, API calls, storage, ...) with reset periods

Verified

- 5 configuration-validation tests and 3 URL-rule tests
- 4 catalogue integration tests: registration rules, edits, version publish/rollback, feature rules

Open item

- Per-company values for product settings (Phase 7); product logos (needs safe file uploads)

Phase 6 — Plans, subscriptions & entitlements

Planned

Delivered / scope

- Plans, prices, included products and feature limits
- Subscription states (trial, active, past due, suspended, cancelled, expired) with defined transitions
- Upgrades immediate, downgrades at renewal; entitlement calculation; atomic usage limits
- Scheduled renewals and expiry; grace period decided here

Phase 7 — Provisioning & sample product

Planned

Delivered / scope

- Documented integration contract for product services
- Durable provisioning jobs with retries, back-off and manual retry
- Sample product service with its own database

Phase 8 — Frontend portals

Planned

Delivered / scope

- Login, navigation by permission, company switcher
- Super Admin: dashboard, companies, users, products, plans, subscriptions, provisioning, audit
- Company Admin: dashboard, profile, products, subscription, users, roles, usage, billing

Phase – — Billing (Razorpay)

Planned

Delivered / scope

- Razorpay integration behind a gateway interface; invoices and payment records
- Verified, idempotent payment webhooks

Phase 9 — Hardening

Planned

Delivered / scope

- Security review and dependency scans
- Tenant-isolation suite across all company endpoints
- Load tests against agreed targets (measured, never assumed)
- Backup and restore drill

Phase 10 — Deployment

Planned

Delivered / scope

- Production deployment with TLS and secrets management
- Monitoring, alerting, runbooks and verified rollback

Risks

#	Risk	Mitigation
R-1	Flyway is officially verified only up to MySQL 9.4	All migrations run on MySQL 9.7 in tests; fall back to MySQL 8.4 LTS if a defect appears
R-2	Spring Boot 4 / Jackson 3 ecosystem is new	Prefer Boot-managed libraries; check compatibility before adding any
R-3	Self-hosted Keycloak must be operated	Two-node setup, backups and upgrade runbook in Phase 10
R-4	Scale targets unproven	Load tests in Phase 9 with measured results

Open decisions

#	Decision	Needed by	Default if not answered
D-5	Grace period and data retention after cancellation	Phase 6	Decide when subscriptions are built
D-6	Confirm availability and latency targets	Phase 9	99.9% availability; p95 under 300 ms for reads
D-7	Can Company Admins buy or upgrade plans themselves?	Phase 6 / 8	Super Admin assigns plans
D-8	Self-registration or invitation only?	Phase 4	Invitation only
D-9	How users open products (subdomains vs one gateway)	Phase 7	Separate subdomains with single sign-on
D-10	Personal-data retention and export obligations	Phase 9	Export and deletion workflows, configurable retention